

Clase 306 — Capstone: detección Blue Team end-to-end

Parte: **16 — Capstones y preparación de certificaciones** · Fuente: MITRE ATT&CK® · *The Practice of Network Security Monitoring (Bejtlich)* 🕒 Duración estimada: **150 min** · Nivel: **Avanzado**

Objetivo

Construir una **capacidad de detección Blue Team end-to-end**: instrumentar hosts y red, centralizar logs en un SIEM, escribir reglas de detección, generar alertas y medir la **cobertura ATT&CK** frente a la operación Red Team de la Clase 305. Integra las Partes 10 (SIEM/logging), 11 (threat hunting) y 12 (IR) en un proyecto verificable que demuestra que "ves" al adversario.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Instrumentar** hosts Windows/Linux con telemetría útil (Sysmon, auditd).
2. **Centralizar** logs en un SIEM (Elastic/Wazuh) y normalizarlos.
3. **Escribir** reglas de detección (Sigma) y desplegarlas.
4. **Cazar** técnicas concretas del ataque Red Team y validar alertas.
5. **Medir** la cobertura de detección con ATT&CK Navigator.

Temas

#	Tema	Por qué importa
1	Telemetría de host (Sysmon/auditd)	Sin datos no hay detección
2	Centralización en SIEM	Correlación y búsqueda a escala
3	Reglas Sigma y despliegue	Detección portable y versionable
4	Threat hunting (Parte 11)	Encontrar lo que las reglas no ven
5	Alertas y triage	Priorizar señal sobre ruido
6	Cobertura ATT&CK	Medir madurez de detección
7	Métricas (MTTD, FP rate)	Demostrar mejora objetiva

Definiciones y características

- **Sysmon**: sensor de eventos de Windows (procesos, red, hashes). *Característica*: telemetría rica y configurable por XML.
- **SIEM**: plataforma de agregación y correlación de logs. *Característica*: centraliza y permite búsquedas.

- **Regla Sigma:** firma de detección en YAML agnóstica del SIEM. *Característica:* se traduce a la query nativa del backend.
- **Cobertura ATT&CK:** proporción de técnicas que sabes detectar. *Característica:* se visualiza en Navigator.
- **MTTD (Mean Time To Detect):** tiempo medio hasta detectar. *Característica:* métrica clave de un SOC.
- **Falso positivo:** alerta sin amenaza real. *Característica:* erosiona la confianza; hay que ajustar reglas.

Herramientas y preparación

- SIEM de laboratorio: **Wazuh** o **Elastic Stack** (Elasticsearch + Kibana).
- Telemetría: **Sysmon** con una config de referencia (SwiftOnSecurity/Olaf Hartong) y **auditd** en Linux.
- Detección: **Sigma** + `sigmac` / `sigma-cli`, reglas de la comunidad.
- Datos: los eventos generados por el capstone Red Team (Clase 305).
- ATT&CK Navigator para el mapa de cobertura.

Laboratorio guiado

1. **Instrumenta.** Despliega Sysmon con una config de referencia en los hosts Windows y `auditd` con reglas clave en Linux.
2. **Centraliza.** Instala Wazuh/Elastic y envía los logs de todos los hosts; verifica la ingesta en Kibana.
3. **Normaliza.** Comprueba que campos clave (proceso, línea de comandos, hash, usuario) llegan parseados.
4. **Despliega reglas Sigma.** Importa reglas para técnicas del ataque (p. ej. `T1059` ejecución por línea de comandos, `T1003` volcado de credenciales, `T1021` movimiento lateral).
5. **Reproduce el ataque.** Vuelve a lanzar (o usa los logs de) la operación Red Team de la Clase 305.
6. **Valida detecciones.** Confirma qué técnicas generaron alerta y cuáles pasaron desapercibidas.
7. **Caza lo no detectado.** Para las técnicas sin alerta, escribe una query de hunting y, si procede, una regla nueva.
8. **Mide cobertura.** Colorea en ATT&CK Navigator: verde (detectado), amarillo (visible sin regla), rojo (ciego).
9. **Calcula métricas.** Estima MTTD por técnica y tu tasa de falsos positivos.
10. **Informe.** Documenta gaps, reglas nuevas y plan de mejora.

Ejercicios

1. Escribe una regla Sigma para detección de `mimikatz` /volcado de LSASS.
2. Ajusta una regla ruidosa para reducir falsos positivos.
3. Crea un dashboard con las alertas por técnica ATT&CK.
4. Compara la cobertura antes y después de añadir 3 reglas.
5. Redacta una query de hunting para movimiento lateral por SMB.
6. Calcula el MTTD de tres técnicas del ataque.

Reto verificable

Entrega un **informe de detección Blue Team** (`informe-blueteam.md`) con: arquitectura de telemetría y SIEM, al menos 5 reglas Sigma desplegadas, la validación contra el ataque de la Clase 305, un mapa de cobertura ATT&CK (Navigator) y un plan para cerrar los gaps ciegos.

Criterio de aceptación: al menos 5 técnicas del ataque están detectadas y evidenciadas con capturas de alerta, el mapa de cobertura distingue detectado/visible/ciego, y hay reglas nuevas escritas para al menos 2 gaps.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"No llegan logs al SIEM"	Agente/forwarder mal configurado; revisa conectividad e índices.
"Sysmon no captura línea de comandos"	Config mínima; usa una config de referencia completa.
"Demasiadas alertas"	Reglas sin ajustar; añade excepciones y umbrales.
"La regla Sigma no traduce"	Backend incorrecto en <code>sigmac</code> ; especifica el SIEM destino.
"No detecto nada del ataque"	Telemetría incompleta; verifica qué eventos genera cada técnica.

Preguntas frecuentes

? ¿Wazuh o Elastic? Wazuh es más rápido de montar y trae reglas; Elastic es más flexible. Cualquiera vale para el capstone.

? ¿Qué config de Sysmon uso? Parte de la de SwiftOnSecurity u Olaf Hartong y ajústala; evita la config por defecto (casi vacía).

? ¿Cómo priorizo qué detectar? Empieza por las técnicas que usaste en la Clase 305 y por las de mayor impacto (ejecución, credenciales, persistencia).

? ¿Detección al 100%? No es realista. El objetivo es maximizar cobertura de las técnicas relevantes y conocer tus puntos ciegos.

Referencias

- MITRE ATT&CK®: <https://attack.mitre.org/>
- Sigma: <https://github.com/SigmaHQ/sigma>
- Wazuh: <https://wazuh.com/> · Elastic Security: <https://www.elastic.co/security>
- Sysmon (Sysinternals): <https://learn.microsoft.com/sysinternals/downloads/sysmon>
- Bejtlich, *The Practice of Network Security Monitoring*.

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Siguiendo clase

Clase 307 - Capstone: respuesta a incidentes DFIR end-to-end